

WriteUp - Neighbour - Tryhackme

Caio de Godoy

First thing we can see is a message giving some context, a good hint of the vulnerability.

Check out our new cloud service, Authentication Anywhere -- log in from anywhere you would like! Users can enter their username and password, for a totally secure login process! You definitely wouldn't be able to find any secrets that other people have in their profile, right?

After a basic scan of the target, its possible to see just a SSH and a HTTP service open.

```
(root@kali)-[/home/kali]
# nmap -sV 10.66.153.186
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-03 21:27 -03
Nmap scan report for 10.66.153.186
Host is up (0.16s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.53 ((Debian))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.27 seconds
```

Accessing the web application through the IP address led to a login page.

Login

Please fill in your credentials to login.

Username

Password

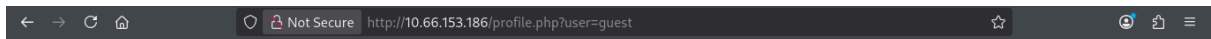
Login

Don't have an account? Use the guest account! (Ctrl+U)

i dont have any credentials, so i gonna see that guest account, using the Ctrl + U, it redirect to the view source page, giving the login and password *guest:guest*

```
33 <p>Don't have an account? Use the guest account! (<code>Ctrl+U</code>)</p>
34 <!-- use guest:guest credentials until registration is fixed. "admin" user account is off limits!!!! -->
```

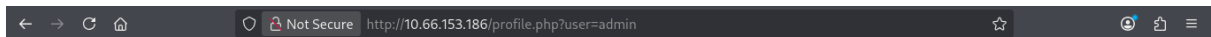
This is the guest's site, a very welcoming and useful site for the guests as we can see



Hi, **guest**. Welcome to our site. Try not to peep your neighbor's profile.

[Sign Out of Your Account](#)

Looking at the URL, its possible to try the IDOR, because it expose user-data in it parameters. Using the "admin" as user.



Hi, **admin**. Welcome to your site. The flag is:
and is possible to get the flag!

This vulnerability allows unauthorized users to access restricted data by simply modifying request parameters. It highlights a lack of proper access control mechanisms on the server side, and also, sensitive information, the admin username, disclosure through HTML comments and weak credential management.

This lab demonstrates how improper authorization and poor handling of sensitive information can lead to critical security issues.